

Name: Chan Chi Fai SID:22063545D

Q1.1.

SSL record protocol provides confidentiality and message authentication.

Using encryption to provide confidentiality and use MAC to provide message authentication.

Q1.2.

SSL uses server authentication. Server authentication through Certificate and key exchange. The certificate associates the public key with the identity. The certificate will use X.509.

SSH uses client authentication. Authenticates the client-side user to the server. SSH follows an authentication process by the server's verification done client, session key generation and the client's authentication.

Q1.3.

Two major purposes of SSL Handshake protocol is establish and share master secret and authentication: server and (optionally) client authentication.

Q2.1.

Because A has shared a secret key k with all the recipients. Other recipients can also send the message with MAC $\tau = \text{MAC}(k, m)$ and say the message is come from A. So it can not ensure message authentication that the message comes from A or other recipient.

Q2.2.

The condition is no two recipients B_i and B_j (where $i \neq j$) should have the exact same subset of keys, i.e., $S_i \neq S_j$ for all $i \neq j$.

Because if any two recipients have the exact same subset of keys, one recipients can make the fake message to the other one recipient that have

have subset of keys. So all the subset of keys should be unique.

Q2.3.

The secret keys for each recipient:

$$S1=\{k1, k2\}$$

$$S2=\{k2, k3\}$$

$$S3=\{k3, k4\}$$

$$S4=\{k4, k5\}$$

$$S5=\{k1, k2, k3\}$$

$$S6=\{k2, k3, k4\}$$

$$S7=\{k3, k4, k5\}$$

$$S8=\{k1, k2, k3, k4\}$$

$$S9=\{k1, k2, k3, k5\}$$

$$S10=\{k2, k3, k4, k5\}$$

Q3.1.

PK = (n, e), SK = (n, d).

RSA signature= $m^d \bmod n = \sigma$

Sig= $m^d \bmod n \rightarrow \sigma$

Veri= $(\sigma)^e \bmod n = m$

Eve knows PK = (n, e)

So Eve can generate any σ and computes m by $(\sigma)^e \bmod n$. (by using

Veri= $(\sigma)^e \bmod n =$)

Then Eve can pass the verification using this generated pair of σ and corresponding m .

So, Eve can forge a valid (m, σ) to pass the verification.

Q3.2.

Now verification is $H(m) = \sigma^e \bmod n$.

The relationship of m and σ has change. $H(m)$ is random and unpredictable. Because a secure Hash function is non-invertible and collision-

resistant, given x and $H(x)$, hard to find another y such that $H(y) = H(x)$. Even Eve chooses σ arbitrarily, computing $m = \sigma^{(e) \bmod n}$ does not help because $H(m)$ will not match this m .

Q4.

Certificate Authority (CA) has used the digital signature to sign on the certificate. So the user can verify the certificate's authenticity by comparing the decrypted signature using the CA's public key and the hash of the certificate contents. If it is a match, then the content is integrity. Nothing has changed. Also, authentication and non-repudiation. This certificate must come from CA and CA can not repudiate, because only the CA will have this digital signature. At last, establish trust. The user can trust the public key inside the certificate for communication with others.

Q5.1

Because in step 1 A encrypt a nonce $N1$ using B' 's public key PUb . So only B can decrypt the the message and know $N1$. So in step 2 B respond the

message include N_1 , then when A decrypt the message and found N_1 inside message. So A can authenticate the message is come from B.

Q5.2

Because in step 2 B encrypt a nonce N_2 using A' 's public key PUA . So only A can decrypt the the message and know N_2 . So in step 3 A respond the message include N_2 , then when B decrypt the the message and found N_2 inside message. So B can authenticate the message is come from A.

Q5.3

There have two encryption in $E(P_{Ub}, E(P_{Ra}, K_s))$. $E(P_{Ra}, K_s)$ and $E(P_{Ub}, E(P_{Ra}, K_s))$.

First $E(P_{Ra}, K_s)$ is encrypted by the A private key P_{Ra} , B can decrypted by A public. Only A will have the private key P_{Ra} , so B can know the session K_s must come from A. This acts as a digital signature to let B ensuring that the

session key K_s was generated and sent by A. A can not repudiation for it.

Second $E(P_{Ub}, E(P_{Ra}, K_s))$, using B public key P_{Ub} to encrypt. So, only B can decrypt the session key. It can provide the confidentiality, ensure no other can see the session key.

These two encryption operations provide the session key is secure, authenticated.